INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

GRC 103 Practical Laboratory

RANSOMWARE RISK TREATMENT CASE LAB

BY

MIRACLE NWADIARU

C11/26/CGRCE/17587

TASK 1: ASSESS AND PRIORITISE THE RISKS

1.1 Background

In 2021, Ireland's Health Service Executive (HSE) experienced a ransomware attack following a phishing email attachment opened by an employee in March. The ransomware was activated in May, resulting in files being encrypted and information being copied. The HSE confirmed that no ransom was paid.

This incident demonstrates how phishing can lead to serious security breaches and disruption of healthcare services. It highlights the importance of staff awareness, early detection and effective recovery arrangements.

1.2 Identified Risks

Based on the fictional Northbridge scenario, four major risks were identified:

1. **Service disruption:** Untested recovery arrangements could prevent the clinics from restoring essential booking systems after a ransomware attack.
2. **Sensitive-data loss:** Phishing and ransomware could expose confidential patient records.
3. **Supplier exposure:** An unused but enabled supplier workflow creates unnecessary access to organisational systems.
4. **Delayed detection:** The absence of an assigned phishing escalation owner could delay incident response.

The initial assessment identified two critical risks (service disruption and sensitive-data loss) and two high risks (supplier exposure and delayed detection). Critical risks require immediate treatment, while high risks require management and board attention.

The detailed risk register, including likelihood, impact, scores and risk owners, is provided in the accompanying Excel workbook.

TASK 2: CHOOSE AND JUSTIFY A TREATMENT PORTFOLIO

2.1 Initial Treatment Decision

I recommend a combination of avoidance and mitigation to address Northbridge's security weaknesses.

The selected treatments are:

- **Option A – Avoidance:** Retire the unused supplier workflow to eliminate unnecessary access.
- **Option B – Mitigation:** Introduce multi-factor authentication (MFA) and review account permissions to reduce unauthorized access.

- **Option C – Mitigation:** Implement protected backups, restoration testing and a recovery plan to support business continuity.
- **Option D – Mitigation:** Introduce managed detection and incident escalation to improve threat identification and response.
- **Option E – Mitigation:** Provide staff awareness training and establish a formal phishing reporting process.

The initial portfolio has an estimated cost of **$88,000**, leaving **$12,000** from the available budget.

2.2 Rejected Alternatives and Treatment Approaches

Option F (network segmentation) is deferred to a later phase because immediate priorities include recovery, access security and incident detection.

Option G (cyber insurance) was considered as a transfer option. However, insurance does not prevent attacks or guarantee full compensation for losses.

Overall, avoidance and mitigation are the preferred treatments. Transfer may provide additional financial protection, while acceptance should only apply to eligible residual risks with management approval and a review date. Northbridge remains accountable for its security even when services are outsourced or insurance is purchased.

TASK 3: CALCULATE RETAINED FINANCIAL EXPOSURE

Option G provides a $25,000 deductible and a maximum insurer payment of $250,000 per covered claim.

Scenario 1: Covered loss of $180,000

Insurer payment = $180,000 − $25,000 = **$155,000**

Retained loss = $180,000 − $155,000 = **$25,000**

Scenario 2: Covered loss of $400,000

The amount after the deductible is $375,000. However, the insurer payment is limited to $250,000.

Retained loss = $400,000 − $250,000 = **$150,000**

If a claim is excluded, the insurer makes no payment and Northbridge bears the entire loss.

The annual insurance premium was not provided, so the exact first-year outlay cannot be determined. The full calculations are presented in the accompanying Excel workbook.

TASK 4: RESPOND TO A CHANGE

The situation changes when the restoration test fails and the clinics can only continue using paper bookings for four hours. In addition, the cost of Option B increases from $25,000 to $35,000.

I recommend retaining the five selected treatments while adjusting the MFA allocation. The revised portfolio totals **$98,000**, leaving **$2,000** from the available budget.

The failed restoration test makes system recovery an immediate priority. The IT Manager must investigate the failure, correct the identified weaknesses and demonstrate successful restoration. The Clinic Operations Manager should also review the paper-booking arrangement to ensure essential services can continue during a prolonged outage.

Network segmentation remains deferred due to the limited budget.

The failed restoration test must be escalated to the board because Northbridge has not yet demonstrated that it can recover its essential systems within an acceptable timeframe.

TASK 5: PLAN AND COMMUNICATE THE RESPONSE

5.1 Thirty-Day Treatment Plan

Action	Owner	Cost	Target
Retire unused supplier workflow	IT Manager	$5,000	Days 1–5
Implement MFA and review accounts	IT Manager	$35,000	Days 1–15
Protect backups and investigate restoration failure	IT Manager	$30,000	Days 1–20
Introduce managed detection and escalation	Security Manager	$20,000	Days 5–25
Conduct awareness training and establish reporting	HR/Security Manager	$8,000	Days 10–30
Total		**$98,000**	

Effectiveness will be assessed through access checks, successful restoration testing, simulated security alerts and phishing reporting exercises. Controls must be tested before being considered effective.

5.2 Proposed Residual Risks

The proposed residual scores are:

Risk	Initial Score	Residual Score	Rating
Service disruption	20	20	Critical
Sensitive-data loss	20	15	High
Supplier exposure	12	3	Low

Delayed detection	16	8	Medium

These are estimates based on the expected performance of the treatments. Service disruption remains critical because the restoration test failed. Sensitive-data loss remains high because the impact of exposing patient information is still significant.

The detailed residual risk calculations are provided in the Excel workbook. All scores should be reviewed after implementation and testing.

5.3 Time-Limited Risk Acceptance

I recommend considering temporary acceptance only for the residual delayed-detection risk, provided the reporting and monitoring controls have been implemented and tested.

The Security Manager will own the risk, with acceptance expiring 30 days after formal approval by the Board Risk Committee. A failed phishing simulation, missed alert or new incident will trigger an immediate review.

The critical recovery risk and high sensitive-data risk should not be accepted as substitutes for further treatment.

5.4 Board Memo

TO: Board of Directors, Northbridge Community Health
FROM: Risk Assessment Team
SUBJECT: Approval of Revised Ransom ware Risk Treatment Plan

Following the ransom ware risk assessment, the Risk Assessment Team recommends that the Board approve a revised first-year cybersecurity treatment budget of **$98,000**, which remains within the organization's $100,000 budget limit.

The proposed treatment portfolio focuses on reducing the likelihood and impact of ransom ware attacks while protecting patient information and maintaining essential healthcare services. Key actions include retiring the unused supplier workflow, implementing multi-factor authentication (MFA), strengthening backup protection and recovery arrangements, introducing managed security monitoring, and providing targeted staff awareness training.

A major concern identified during the assessment is the failed restoration test. The clinics can only maintain bookings manually using paper records for approximately four hours. A prolonged disruption could therefore affect appointment scheduling, service delivery and patient care. The IT Manager should investigate the restoration failure, identify the underlying causes and conduct another recovery test. Backups and recovery arrangements should not be considered effective until successful restoration has been demonstrated.

The revised portfolio includes the increased MFA cost of $35,000 and totals $98,000, leaving a balance of $2,000. Network segmentation has been deferred because the available budget is

insufficient to fund all proposed improvements at this stage. This decision should be reviewed in the next budget cycle.

The Board is requested to:

1. Approve the revised $98,000 treatment budget and proposed activities.
2. Assign responsibility to the designated risk owners and require progress updates.
3. Require evidence of successful backup restoration and recovery testing.
4. Review the remaining high and critical risks and approve any time-limited risk acceptance through the appropriate authority.
5. Require a progress and effectiveness review at the end of the 30-day implementation period.

The organisation should prioritise continuity of patient services, protection of confidential health information and timely recovery from cyber incidents.